EWB COURSES

ASSESSMENT 01

Security Foundations

Individual Assessment Report

Student name	Damini K R
Batch / Group	1st batch Cyber security
Assessment issued	18 October 2026
Report date	21 October 2026

This report analyses the fictional scenarios and synthetic evidence supplied in the assessment. It does not test real systems or establish the identity of any person.

Introduction

This report answers Tasks A–D of Assessment 01: Security Foundations. It applies confidentiality, integrity and availability (CIA), practical account protection, phishing-message analysis, sign-in alert triage, and critical review of AI-generated security advice. All examples are treated as fictional training evidence. Conclusions are separated from facts, and uncertainty is stated where the evidence is insufficient.

Task A — Secure a student account (25 marks)

A1. Risks, assets and CIA impact

Risk	Asset at risk	CIA impact
Short/reused password	Mira's email and learning-portal account	Confidentiality: another person may read private email or coursework. Integrity: they could change submissions or account details. Availability: they could lock Mira out.
Unexpected sign-in prompts approved without checking	Account session and MFA protection	Confidentiality and integrity may be affected if an attacker gains access. Repeated approvals can defeat the purpose of MFA.
Delayed device updates	Laptop, browser and saved sessions	Confidentiality and integrity may be affected if known vulnerabilities are exploited; malware could also reduce availability.
Only one copy of project work on the laptop	Coursework and project files	Availability: device failure, theft or ransomware could destroy access to the only copy. Integrity may be affected if files are altered.
Friend uses laptop while Mira is signed in	Email, portal and stored files	Confidentiality: the friend may view private information. Integrity: accidental or intentional changes may be made. Availability: files or settings could be deleted.

A2. Practical controls, limitations and priority order

Priority	Control and why it helps	Limitation
1	Change the short/reused password to a long, unique password. Use a password manager if available. This reduces the chance that a password exposed elsewhere can open the account.	A strong password cannot stop every phishing attack or malware infection.
2	Do not approve unexpected MFA prompts. Deny them, change the password from a trusted device and report repeated prompts to the college IT team. This blocks simple prompt-bombing attempts.	MFA is less protective if the user is tricked into approving a request or revealing a one-time code.
3	Install operating-system, browser and application updates promptly, preferably with automatic updates enabled. This fixes known security weaknesses.	Updates may need a restart and cannot protect against every new or unknown vulnerability.
4	Back up coursework to an approved cloud service or external drive, and check that files can be restored. Keep a separate copy so one device failure does not remove all work.	A backup that is always connected or not tested may also be deleted, encrypted or unusable.
5	Lock the screen when away; use a separate device account for the friend and sign out of email and the portal after use. This reduces casual access to signed-in accounts.	A screen lock does not prevent access if the password/PIN is shared or the session is left unlocked.

Recommended order: secure the account first (unique password and reject unexpected MFA), then patch the laptop, protect files with backups, and reduce shared-device access. If a suspicious prompt has already been approved, report it promptly and ask IT to review active sessions.

A3. Authentication versus authorisation

Authentication checks who a user is—for example, Mira enters her username and password and confirms a valid MFA request to sign in to the learning portal. **Authorisation** decides what an authenticated user is allowed to do—for example, Mira may view her own grades and upload coursework, while only an authorised lecturer may edit marks. Signing in successfully does not automatically give a user permission to access every file or change every record.

Task B — Analyse a suspicious message (25 marks)

B1. Warning signs in the supplied message

Quoted phrase	Why it needs scrutiny
“FINAL WARNING”	Alarmist wording is designed to create fear and reduce careful checking.
“scholarship expires in 20 minutes”	Artificial urgency pressures the recipient to act before verifying the claim.
“Reply-To: help@personal-awards.example”	The reply address differs from the sender’s awards address and does not match the stated campus domain.
“enter your college password and OTP”	A legitimate scholarship process should not ask a student to disclose their password or one-time passcode through an email link.
“Do not contact the college office”	Discouraging independent verification is a strong warning sign because it isolates the recipient from trusted support.
“Reply with a photo of your identity card”	Requesting identity documents by reply may expose sensitive personal information and create identity-theft risk.
“Open https://campus-awards.example/verify”	The domain differs from the scenario’s normal campus.example domain. HTTPS only encrypts the connection; it does not prove the site or sender is genuine.

The sender display name and the scholarship claim are not proof of legitimacy. The supplied .example addresses are fictional training examples and must not be visited.

B2. Safe verification process

1. Do not click the link, reply, open attachments or provide credentials, OTPs or identity documents.
2. Open the college’s official portal using a saved bookmark or type the known official address independently; do not use the message link.
3. Contact the scholarship office using a phone number or email address obtained independently from the college’s official website, student handbook or campus directory.
4. Report the message through the college’s official IT/security reporting channel and preserve the message, sender and headers if requested.
5. Wait for confirmation from the legitimate office before taking action.

HTTPS and a familiar-looking page name do not establish that the sender is genuine. HTTPS generally protects data in transit between a browser and a site, but a fraudulent site can also use HTTPS.

B3. Response plan if a student already entered a password and OTP

1. Immediately contact the college IT/security team using an independently verified channel and explain that credentials and an OTP may have been exposed. Do not send the password or OTP to the helper.
2. From a trusted device, change the affected password to a unique one. If it was reused, change it on other accounts too.
3. Ask IT to revoke active sessions, review sign-in activity, reset MFA if necessary and check for unauthorised recovery methods or account changes.
4. Do not approve further unexpected MFA prompts. Deny and report them.
5. Preserve the email and relevant timestamps for investigation; do not delete evidence before IT advises.
6. Check sent mail, forwarding rules, recovery details, coursework and other account activity for unexpected changes.
7. Follow IT’s advice on device scanning and continue monitoring the account. If identity documents were sent, ask the college what privacy or identity-protection steps are appropriate.

B4. What cannot be established from the message alone

The message alone cannot prove who sent it, whether a real scholarship exists, whether the linked site is controlled by an attacker, or whether any account has been compromised. Helpful additional evidence includes full email headers, verified information from the official scholarship office, domain and website records collected by authorised staff, and security logs showing whether anyone submitted credentials or accessed an account. The message contains strong warning signs, but the assessment is not proof of a real sender’s identity.

Task C — Triage a sign-in alert (25 marks)

C1. Four-point timeline: observed events and interpretation

Time (IST)	Observed evidence	Interpretation (not a proven fact)
09:00–09:01	Password succeeded from 192.0.2.10; MFA was approved.	This matches the lab's usual classroom egress and appears to be a successful sign-in. It does not by itself prove who used the account.
10:14–10:15	Two password attempts from 198.51.100.23 failed.	The account received failed attempts from a different source IP. These could be mistakes or unauthorised attempts; the IP alone does not identify a person.
10:16–10:17	Password succeeded from 198.51.100.23; MFA was denied at 10:17.	The password was accepted, but the MFA denial suggests the sign-in was not fully completed at that moment. It may indicate a user rejecting an unexpected prompt.
10:18–10:20	MFA was approved at 10:18 and a session was created at 10:20. The student says they approved a prompt believing it would stop repeated requests and did not sign in after 09:05.	A session was created after the approval. This is consistent with a possible attacker using a password and obtaining MFA approval, but the logs do not prove who controlled the session or whether the student's action caused it.

C2. Likely explanation, alternative explanation and checks

Likely explanation: someone other than the student may have attempted to sign in using the correct password. After failed attempts, the password succeeded; an MFA prompt was first denied and then approved. A session was created two minutes later. The student's statement makes accidental approval of an unexpected prompt a concern, so the account should be treated as potentially compromised until checked.

Alternative explanation: the student may have initiated a legitimate sign-in from a different network or device, mistyped the password several times, and then approved MFA. The student may not remember or recognise the sign-in. A different IP address alone is not proof of an attacker.

Two useful checks: (1) Ask the student to confirm devices, networks, browser activity and exact prompt times, without requesting their password or OTP. (2) Review authorised identity-provider/session logs for device/browser details, session token use, location or network context, and any account changes after 10:20. Compare with known legitimate sign-ins and check whether the session accessed files or changed settings.

C3. Three prioritised actions for the authorised IT team

1. Contain the possible compromise: contact the student through a verified channel, revoke the newly created session and other suspicious sessions, and reset the password. Require MFA re-registration if there is evidence that MFA settings or recovery methods were changed.
2. Preserve evidence: export and securely retain sign-in, MFA, session and relevant audit logs with timestamps and time zone; record actions taken and maintain an incident timeline before logs expire. Avoid changing or deleting evidence unnecessarily.
3. Investigate and protect: check for account changes, mailbox forwarding rules, suspicious file access, new devices and further sign-ins. Apply additional controls if needed, advise the student not to approve unexpected prompts, and monitor for repeat activity.

C4. Incident summary (60–100 words)

Synthetic logs show a successful password and MFA sign-in from the usual classroom egress at 09:00–09:01. At 10:14–10:15, two password attempts from another reserved example IP failed, followed by a password success at 10:16, an MFA denial at 10:17, an approval at 10:18 and session creation at 10:20. The student says they did not sign in after 09:05 and approved a prompt to stop repeated requests. Account compromise is plausible but not proven. Priority: revoke suspicious sessions, reset credentials, preserve logs and investigate account activity.

Task D — Review an AI security answer (25 marks)

D1. Five unsafe or unsupported claims/actions and corrections

AI claim/action	Correction and reason
“The email is safe because it uses HTTPS.”	Incorrect. HTTPS encrypts traffic but does not verify that a message or website is trustworthy. A phishing site can use HTTPS.
“The sign-in logs prove the person using 198.51.100.23 stole the password.”	Unsupported. The logs show events associated with a source IP, not the identity or intention of a person. The address is a reserved documentation example.
“MFA prevents every account compromise.”	Incorrect. MFA lowers risk but can be defeated by approval of an unexpected prompt, phishing, stolen sessions or other weaknesses.
“Delete the suspicious logs.”	Unsafe. Logs may be important evidence. Preserve relevant records securely and follow the authorised incident-response process.
“Send the student’s password to support so they can test it.”	Unsafe. Passwords and OTPs must not be shared. Support staff should use approved reset and verification processes instead.

D2. Better prompt for an AI tool

> “Analyse only the fictional email text and synthetic sign-in log provided below. Identify observed facts separately from interpretations and assumptions. Explain the security risks, but do not claim that an IP address identifies a person or that a compromise is proven unless the evidence supports it. State what cannot be determined and list safe additional checks for authorised staff. Recommend proportionate containment and evidence-preservation steps. Never ask for or reproduce real passwords, OTPs, identity documents, personal data or account screenshots. Do not visit links or test websites. Keep the response clear, cautious and suitable for a student security assessment.”

D3. Corrected security advice (100–150 words)

The scholarship email contains several warning signs: urgent deadline language, a reply address that differs from the sender, a domain that does not match the college’s normal domain, requests for a password and OTP, a request for an identity-card photo, and instructions not to contact the college. Do not click the link or reply. Verify the scholarship through the college’s independently obtained official portal or contact details, and report the message to the authorised IT/security team. HTTPS alone does not prove a site is genuine. The synthetic sign-in log shows a successful session created after an unusual sequence of password and MFA events, but it does not identify a person or prove how the password was obtained. IT should revoke suspicious sessions, reset credentials, preserve logs and review account activity. Never share passwords or OTPs with anyone.

D4. AI-use declaration and evidence/reference notes

AI-use declaration: AI assistance was used to help organise and draft explanations for this assessment. The supplied fictional scenarios and synthetic logs were treated as the evidence. The analysis should be reviewed and understood by the student before submission.

Evidence note 1: Assessment 01, Tasks A–D, issued 18 October 2026: fictional student-account scenario, fictional scholarship message and synthetic sign-in log supplied in the assessment.

Evidence note 2: The assessment’s reference-reading section names CISA Secure Our World for basic account and phishing guidance, and NIST AI 600-1 for generative-AI risk management and verification. Consult the official versions for further study.

Conclusion

The safest approach is to protect accounts with unique passwords, cautious MFA use, timely updates and reliable backups; verify suspicious messages through independently obtained official channels; and respond to sign-in alerts with containment, evidence preservation and further checks. Security conclusions must be proportionate to the evidence. Neither HTTPS nor an IP address alone proves legitimacy or identity, and AI-generated advice must be checked for unsupported claims and unsafe actions.

End of report